

Secure Fintech App

Owner: Saira Saeed

Reviewer:

Contributors:

Date Generated: Mon Jul 27 2026

Executive Summary

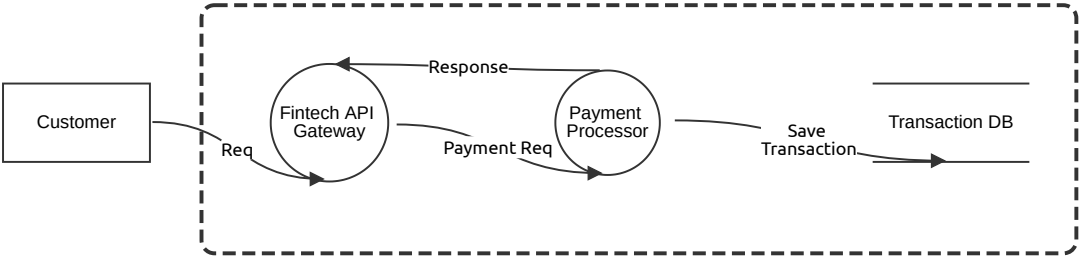
High level system description

Not provided

Summary

Total Threats	4
Total Mitigated	4
Total Open	0
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0

Fintech



Data Flow

Fintech

Customer (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Fintech API Gateway (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Unauthorized Customer/API Impersonation	Spoofing	High	Mitigated		An attacker impersonates a legitimate customer or client application and submits fraudulent payment requests to the Fintech API Gateway.	Enforce OAuth 2.0/OIDC with MFA where applicable, validate JWT tokens, implement mutual TLS (mTLS) for service communication, and apply API rate limiting.
3	API Gateway Resource Exhaustion	Denial of service	Critical	Mitigated		Attackers flood the Fintech API Gateway with excessive requests, preventing legitimate payment processing and causing service disruption.	Implement API Gateway rate limiting, WAF, DDoS protection, request throttling, autoscaling, and circuit breakers with monitoring/alerting.

Payment Processor (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Payment Request Manipulation	Tampering	Critical	Mitigated		Payment amount, recipient account, or transaction details are modified while traveling from the customer to the API Gateway or between internal services.	Use TLS 1.3 for all communications, digitally sign payment requests (HMAC/JWS), perform server-side validation, and verify request integrity before processing.
4	Duplicate Payment / Replay Fraud	Tampering	Critical	Mitigated		A malicious user intercepts or repeatedly sends the same valid payment request, causing multiple unauthorized transactions before detection.	Use idempotency keys, unique transaction IDs/nonces, replay protection with timestamps, duplicate transaction detection, and real-time fraud monitoring.

Transaction DB (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Req (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Payment Req (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Save Transaction (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

Response (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------